



AI Governance Guide for Regulated Organizations

Financial Industry Regulatory Authority (FINRA)

A practical framework for governing AI tools under FINRA requirements — supervision, explainability, and examination readiness.

1. Regulatory Landscape for AI Under FINRA

FINRA AI governance expectations are channeled through existing rules:

- Rule 3110 (Supervision): Firms must supervise all activities, including those conducted by or through AI systems.
- Rule 2010 (Standards of Commercial Honor): AI-driven outputs that harm customers violate just and equitable principles.
- Regulatory Notice 21-16: FINRA initial guidance on AI and ML use in compliance and surveillance.
- FINRA Report on AI in the Securities Industry (2020): Foundational expectations for governance, explainability, and human oversight.
- Rule 4370 (BCP): AI systems with material operational dependencies must be included in business continuity planning.

2. Supervision of AI-Assisted Activities

Rule 3110 requires every activity be supervised by qualified personnel:

- You cannot outsource supervision to an algorithm. A human principal must be responsible for reviewing AI-driven outputs in regulated contexts.
- Written Supervisory Procedures must address which activities use AI, how outputs are reviewed, who is responsible, and escalation procedures.
- For AI used in suitability or recommendations: human review is required before any AI-generated recommendation is delivered to a customer.
- For AI used in surveillance: human review of alerts before regulatory reports are filed.
- Red flag: Firms that let AI auto-close compliance alerts without human review are creating exam exposure under Rule 3110.

3. Explainability and Model Transparency

FINRA expects firms to understand their AI tools, not just deploy them:

- Explainability Standard: For any AI model affecting customers or regulatory obligations, the firm must explain in plain language what the model does, what data it uses, and how it reaches outputs.
- Black-Box Risk: FINRA has specifically flagged black-box AI models as high-risk. Firms using opaque AI should have contractual rights to explainability documentation.

- **Model Validation:** For high-stakes AI including credit decisions, suitability screening, and surveillance, maintain validation records.
- **Change Notification:** Document and review any material changes to AI models.

4. Customer Communication and AI Disclosure

When AI is used in customer-facing contexts:

- **Fair Disclosure:** Customers must not be misled about whether they are interacting with a human or AI system.
- **Suitability Obligations:** AI-driven recommendations remain subject to Reg BI. The firm is responsible for the suitability determination.
- **Communications Review:** AI-drafted communications are subject to the same review requirements as human-authored communications.
- **Recordkeeping:** All AI-assisted customer communications must be retained per Rules 4511 and 4512.

5. Vendor and Third-Party AI Governance

Most firms use third-party AI. FINRA holds the firm responsible regardless:

- **Vendor Selection:** Document your due diligence process including governance documentation, SOC 2, and regulatory compliance track record.
- **Contractual Protections:** Agreements must address data security, breach notification, AI model change notice, and termination rights.
- **Ongoing Oversight:** Annual review of vendor AI governance. Include AI vendors in your Third-Party Risk Management program.
- **Business Continuity:** For critical AI vendors, document contingency if the vendor becomes unavailable per Rule 4370.

6. FINRA Exam Preparation Checklist

Before a FINRA examination, confirm you can produce:

- AI inventory with use-case descriptions and risk classification
- Updated WSPs covering AI supervision across all affected activities

- Explainability documentation for customer-facing and surveillance AI
- Model validation records for high-stakes AI systems
- Vendor due diligence files including AI governance questionnaires
- Evidence of principal review of AI-generated outputs
- BCP documentation including AI system dependencies
- Customer communication samples demonstrating AI disclosure compliance

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/financial-services

Call us: (877) 945-7177